Producción de Software

Pablo Valenzuela

27 Abril 2026

Programa

1. SBOM y cadena de suministro (27 Abril)
2. Generación y análisis de SBOMs (4 de Mayo)
3. Vulnerabilidades de Software (18 de Mayo)
4. Extracción y análisis de vulnerabilidades (25 de Mayo)

Seleccione un repositorio desde Github

1. Caracterize el repositorio en forma breve
2. ¿Qué puede decir de sus dependencias?
3. ¿Podría referirse a sus vulnerabilidades?

SBOMs

- Un **Software Bill of Materials (SBOM)** es un inventario estructurado de los componentes que forman parte de una aplicación o artefacto de software.
- En términos simples, cumple un rol similar al de una lista de ingredientes:
  - identifica bibliotecas, paquetes, dependencias, herramientas y otros elementos utilizados durante el desarrollo, la compilación y la distribución de un sistema.
  - Su valor no está solo en enumerar componentes, sino también en aportar contexto sobre su origen, sus versiones y la relación que mantienen entre sí.

Porciones por envase

Calorías

Nutrition Facts

4 servings per container

Serving size 1 1/2 cup (208g)

Tamaño de la porción

Amount per serving

Calories 240

% de valor diario (%VD)

	% Daily Value*
Total Fat 4g	**5%**
Saturated Fat 1.5g	**8%**
Trans Fat 0g	
Cholesterol 5mg	**2%**
Sodium 430mg	**19%**
Total Carbohydrate 46g	**17%**
Dietary Fiber 7g	**25%**
Total Sugars 4g	
Includes 2g Added Sugars	**4%**
Protein 11g	
Vitamin D 2mcg	10%
Calcium 260mg	20%
Iron 6mg	35%
Potassium 240mg	6%

* The % Daily Value (DV) tells you how much a nutrient in a serving of food contributes to a daily diet. 2,000 calories a day is used for general nutrition advice.

¿Por qué los SBOMs son relevantes?

Entra en vigencia el 01-DIC-2026

LEY 21719 | REGULA LA PROTECCIÓN Y EL TRATAMIENTO DE LOS DATOS PERSONALES Y CREA LA AGENCIA DE PROTECCIÓN DE DATOS PERSONALES

MINISTERIO SECRETARÍA GENERAL DE LA PRESIDENCIA

Generar url corta

Promulgación: 25-NOV-2024

TIENE TEXTO DIFERIDO

Publicación: 13-DIC-2024

Versión: Con Vigencia Diferida por Fecha - 01-DIC-2026

Última modificación: 05-FEB-2026 - Ley 21806

Materias: Protección de Datos Personales, Agencia de Protección de Datos Personales, Ley sobre Protección de la Vida Privada (Ley 19628), Datos de Carácter Personal, Ley sobre Acceso a la Información Pública (Ley 20285), Ley del Consumidor, Derecho a la portabilidad de los datos personales, Registro Nacional de Sanciones y Cumplimiento, Derechos del Titular de Datos Personales, Datos Personales, Datos Personales Sensibles, Categorías Especiales de Datos Personales, Tratamiento de Datos Personales, Transferencia Internacional de Datos Personales, Infracciones a la Ley de Protección de Datos Personales

Resumen: La presente ley introduce modificaciones a la Ley Nº 19.628, sobre Protección de la Vida Privada, y que ahor ... **ver más >>**

https://www.bcn.cl/leychile/navegar?idNorma=1209272

Software Security in Supply Chains: Software Bill of Materials (SBOM)

Section 10(j) of EO 14028 defines an SBOM as a “formal record containing the details and supply chain relationships of various components used in building software,”[1] similar to food ingredient labels on packaging. SBOMs offer increased transparency, provenance, and speed at which vulnerabilities[2] can be identified and remediated by federal departments and agencies. SBOMs can also indicate a developer or supplier’s application of secure software development practices across the SDLC. Figure 2 illustrates an example of how an SBOM may be assembled across the SDLC.

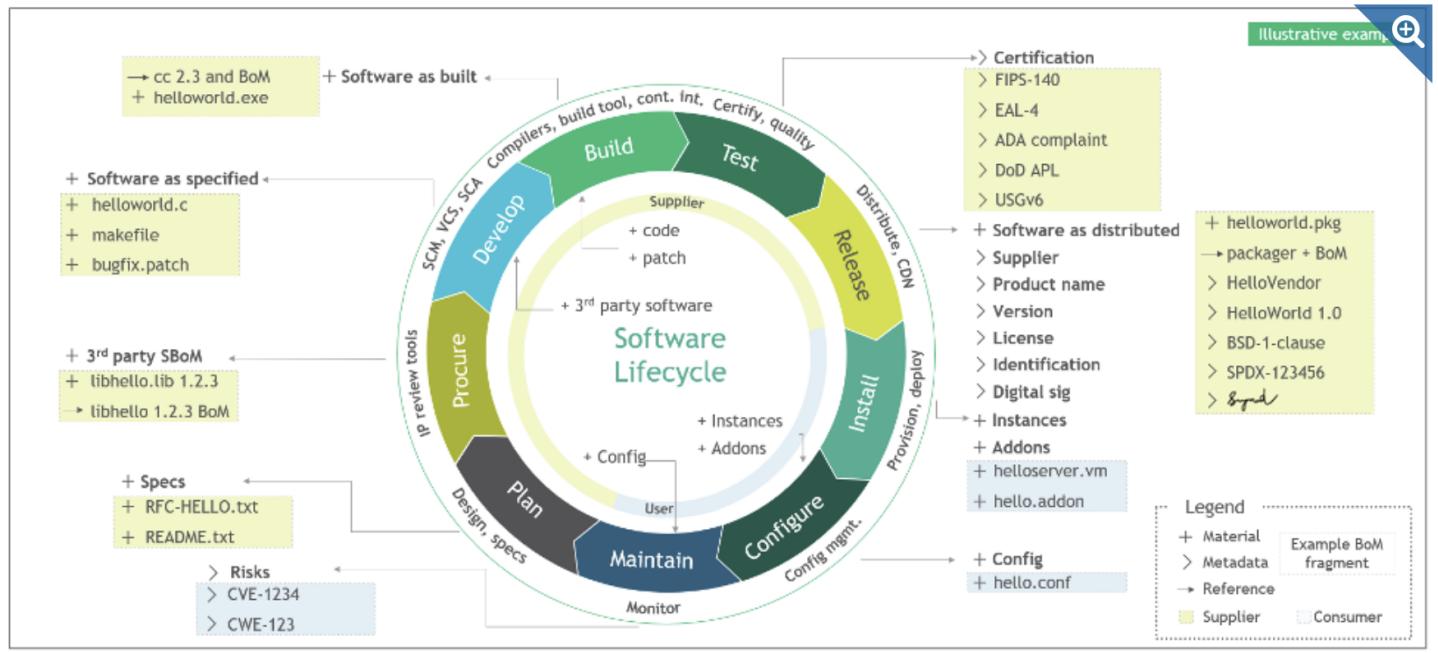


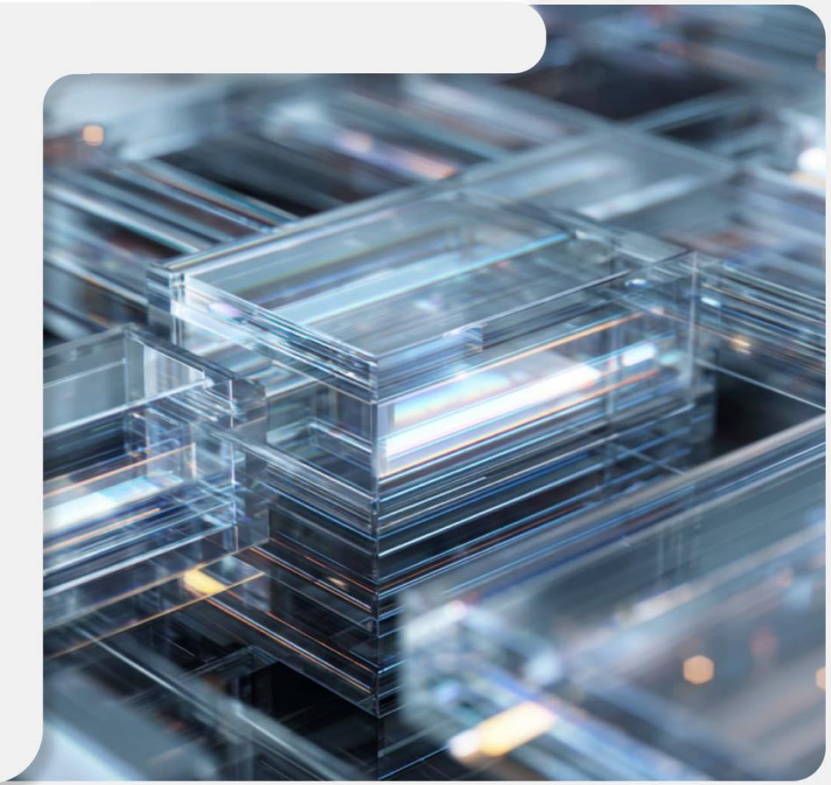
Figure 2 - Illustrative Example of Software Life Cycle and Bill of Materials Assembly Line

BLOG

What is an SBOM and Why Does it Matter for Government Contracts?

2F Team

02.11.2026 / 3 months ago



government-contracts

Fines Database

Fines Statistics

Submit new fine / correction

GDPR ET Report

Filter by country:

Filter by violation (Art.):

All 4 5 5(1) 6
7 8 9 10 12
13 14 15 16 17
18 19 20 21 22
23 24 25 26 27
28 29 30 31 32
33 34 35 36 37
38 39 44 46 48
58 83 88

Ireland: Record fine against Meta Platforms Ireland Limited in the amount of EUR 1.2 billion
The Irish DPA (DPC) has fined Meta Platforms Ireland Limited EUR 1.2 billion for unlawfully transferring personal data to the United States

GDPR Enforcement Tracker

tracked by CMS law·tax·future

The CMS.Law GDPR Enforcement Tracker is an overview of fines and penalties which data protection authorities within the EU have imposed under the EU General Data Protection Regulation (GDPR, DSGVO). Our aim is to keep this list as up-to-date as possible. Since not all fines are made public, this list can of course never be complete, which is why we appreciate any indication of further GDPR fines and penalties. *Please note that we do not list any fines imposed under national / non-European laws (with the exception of fines under the UK GDPR), under non-data protection laws (e.g. competition laws / electronic communication laws) and under "old" pre-GDPR-laws. We have, however, included a limited number of essential ePrivacy fines under national member state laws.*

New features: "ETid" and "Direct URL"!
We have assigned a unique and permanent ID to each fine in our database, which makes it possible to precisely address fines, e.g. in publications. Once an "ETid" has been assigned to a fine, it remains the same, even if the fine is overturned or amended by courts at a later date, or if we add fines that were issued chronologically before. The "Direct URL" (click "+" or on a specific ETid to view details of a fine) can be used to share fines online, e.g. on Twitter or other media.

Show 10 entries

Search:

ETid	Country	Date of Decision	Fine [€]	Controller/Processor	Quoted Art.	Type	Source
ETid-3106	GREECE	2026-02-11	30,000	Vodafone – PANAFON A.E.E.T.	Art. 12 (1), (2), (3), (4) GDPR, Art. 15 GDPR, Art. 18 GDPR	Insufficient fulfilment of data subjects rights	link
ETid-3105	GREECE	2025-12-31	6,000	I Mathisi	Art. 12 (3), (4) GDPR, Art. 15 (1) GDPR, Art. 31 GDPR	Insufficient fulfilment of data subjects rights	link link
ETid-3104	FINLAND	2026-03-02	5,000	Suomen Numerokeskus Oy	Art. 15 (1), (3) GDPR	Insufficient fulfilment of data subjects rights	link link
ETid-3103	CROATIA	2024-02-26	20,000	Company	Art. 6 (1) GDPR, Art. 7 GDPR, Art. 13 (1), (2) GDPR	Insufficient legal basis for data processing	link
ETid-3102	CROATIA	2025-12-18	1,500,000	Bank	Art. 5(1) a), c) GDPR, Art. 6 (1) GDPR, Art 12 GDPR, Art. 13 GDPR, Art. 25 (2) GDPR	Non-compliance with general data processing principles	link
ETid-3101	CROATIA	2025-07-22	50,000	Information and Communication Company	Art. 32 (1) b), d), (2) GDPR	Insufficient technical and organisational measures to ensure information security	link

https://www.enforcementtracker.com/

Type / to search

GitHub Advisory Database

Security vulnerability database inclusive of CVEs and GitHub originated security advisories from the world of open source software.

GitHub reviewed advisories

All reviewed	29,428
Composer	5,654
Erlang	49
GitHub Actions	50
Go	3,606
Maven	6,433
npm	5,910
NuGet	924
pip	4,831
Pub	13
RubyGems	1,045
Rust	1,256
Swift	53

Unreviewed advisories

All unreviewed	299,490

Search by CVE/GHSA ID, package, severity, ecosystem, credit...

29,428 advisories Severity CWE Sort

OpenClaw: Agent gateway config mutations could change protected operator settings Moderate
GHSA-7jm2-g593-4qrc was published for openclaw (npm) 2 days ago

OpenClaw: Bundled MCP/LSP tools could bypass configured tool policy Moderate
GHSA-qrp5-gfw2-gxv4 was published for openclaw (npm) 2 days ago

OpenClaw: Workspace dotenv MiniMax host override could redirect credentialed requests Moderate
GHSA-h2vw-ph2c-jvwf was published for openclaw (npm) 2 days ago

OpenClaw: Browser CDP profile creation skipped strict-mode SSRF checks Low
GHSA-j4c5-89f5-f3pm was published for openclaw (npm) 2 days ago

OpenClaw: Paired-device pairing actions were not limited to the caller device Low
GHSA-xrq9-jm7v-g9h7 was published for openclaw (npm) 2 days ago

OpenClaw: QQBot direct media upload skipped URL SSRF validation Low
GHSA-c4qg-j8jg-42q5 was published for openclaw (npm) 2 days ago

OpenClaw: MCP stdio server env could load dangerous startup variables from workspace config Moderate
GHSA-mj59-h3q9-ghfh was published for openclaw (npm) 2 days ago

OpenClaw: Isolated cron awareness events were recorded as trusted system events Low
GHSA-57r2-h2wj-g887 was published for openclaw (npm) 2 days ago

https://github.com/advisories

Gemini

GitHub Advisory Database / GitHub Reviewed / GHSA-wpqr-6v78-jr5g

Gemini CLI: Remote Code Execution via workspace trust and tool allowlisting bypasses

Critical severity | GitHub Reviewed | Published 4 days ago in **google-github-actions/run-gemini-cli** • Updated 2 days ago

Vulnerability details | Dependabot alerts 0

Package	Affected versions	Patched versions
@google/gemini-cli (npm)	< 0.39.1 = 0.40.0-preview.2	0.39.1 0.40.0-preview.3
google-github-actions/run-gemini-cli (GitHub Actions)	< 0.1.22	0.1.22

Severity

Critical 10.0 / 10

CVSS v3 base metrics

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	High
Availability	High

Learn more about base metrics

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

EPSS score

Weaknesses

- CWE-20
- CWE-77
- CWE-78
- CWE-200

CVE ID

No known CVE

GHSA ID

GHSA-wpqr-6v78-jr5g

Description

Summary

Gemini CLI (`@google/gemini-cli`) and the `run-gemini-cli` GitHub Action are being updated to harden workspace trust and tool allowlisting, in particular when used in untrusted environments like GitHub Actions. This update introduces a breaking change to how non-interactive (headless) environments handle folder trust, which may impact existing CI/CD workflows under specific conditions.

Details

Folder Trust in Headless Mode

In previous versions, Gemini CLI running in CI environments (headless mode) automatically trusted workspace folders for the purpose of loading configuration and environment variables. This is potentially risky in situations where Gemini CLI runs on untrusted folders in headless mode (e.g. CI workflows that review user-submitted pull requests). If used with untrusted directory contents, this could lead to remote code execution via malicious environment variables in the local `.gemini/` directory.

To ensure consistency and user control, the latest update aligns headless mode behavior with interactive mode, requiring folders to be explicitly trusted before configuration files (such as `.env`) are processed.

As a result of this change, GitHub Actions and other automated pipelines that rely on the previous automatic trust behavior will fail to load workspace-specific settings until they are updated to use explicit trust mechanisms.

Tool Allowlisting under --yolo

A Guide to SBOM Requirements & Standards Around the Globe

Posted on February 11, 2025

Author: Jeff Numark

Key Takeaways

- *SBOM (Software Bill of Materials)* ***requirements are becoming mandatory*** *across the U.S., EU, and other global markets.*
- *Major cyber incidents like* ***SolarWinds and Log4Shell accelerated regulatory action*** *around software supply chain transparency.*
- *U.S. regulations—including* ***EO 14028, FDA medical device rules, and the U.S. Army directive****—are turning SBOMs into enforceable contract requirements.*
- ***The EU Cyber Resilience Act (CRA) mandates SBOM generation*** *for products with digital elements sold in the European market.*
- *Healthcare, government contractors, critical infrastructure, automotive, and payment processors face* ***increasing SBOM compliance obligations.***
- *Organizations that operationalize SBOM generation and lifecycle management gain faster vulnerability response, improved compliance readiness, and* ***stronger software supply chain security.***

https://runsafesecurity.com/blog/sbom-requirements-global-guide/

OWASP

PROJECTS CHAPTERS EVENTS ABOUT

OWASP Software Component Verification Standard

Main | News | Acknowledgements

The Software Component Verification Standard (SCVS) is a community-driven effort to establish a framework for identifying activities, controls, and best practices, which can help in identifying and reducing risk in a software supply chain.

Managing risk in the software supply chain is important to reduce the surface area of systems vulnerable to exploits, and to measure technical debt as a barrier to remediation.

Measuring and improving software supply chain assurance is crucial for success. Organizations with supply chain visibility are better equipped to protect their brand, increase trust, reduce time-to-market, and manage costs in the event of a supply chain incident.

Raising the bar for supply chain assurance requires the active participation of risk managers, mission owners, and business units like legal and procurement, which have not traditionally been involved with technical implementation.

Determination of risk acceptance criteria is not a problem that can be solved by enterprise tooling: it is up to risk managers and business decision makers to evaluate the advantages and trade-offs of security measures based on system exposure, regulatory requirements, and constrained financial and human resources. Mandates that are internally unachievable, or that bring development or procurement to a standstill, constitute their own security and institutional risks.

SCVS is designed to be implemented incrementally, and to allow organizations to phase in controls at different levels over time.

SCVS has the following goals:

- Develop a common set of activities, controls, and best-practices that can reduce risk in a software supply chain
- Identify a baseline and path to mature software supply chain vigilance

Availability

SCVS is available (in English) as PDF, Word (docx), JSON, or XML. These artifacts can be found in the projects GitHub releases. It can also be read online.

Translations

The project maintainers are actively looking for volunteers to translate SCVS into a number of languages. Please reach out on the projects Slack channel or on GitHub if interested.

https://owasp.org/www-project-software-component-verification-standard/

¿Por qué los SBOMs han tomado tanta relevancia?

- Cumplimiento normativo
- Seguridad
- ¿En términos concretos, en qué nos podría servir?

Vulnerabilidad crítica en dependencia

- Identifique un caso específico
- Describalo tanto como pueda
- Identifique elementos que caracterizan la vulnerabilidad que usted no entienda

Análisis estático de software (Static program analysis)

- Una **herramienta de análisis estático de código** es un software que revisa el código fuente **sin ejecutarlo**, para detectar errores, vulnerabilidades de seguridad y problemas de calidad antes de que el programa se ejecute.

https://codeql.github.com/

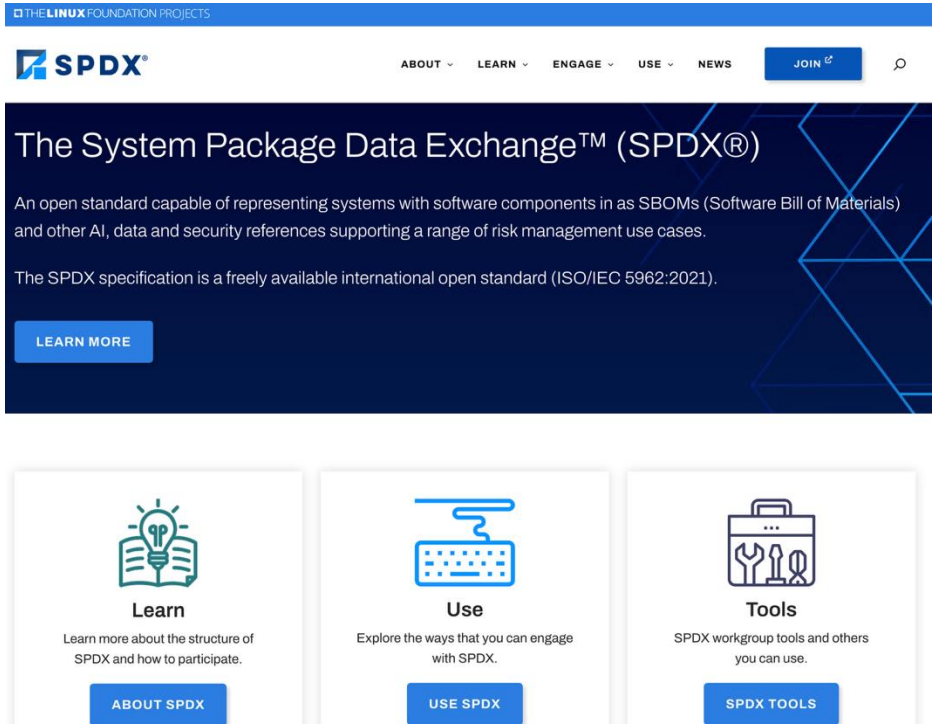
Análisis de composición de software (SCA)

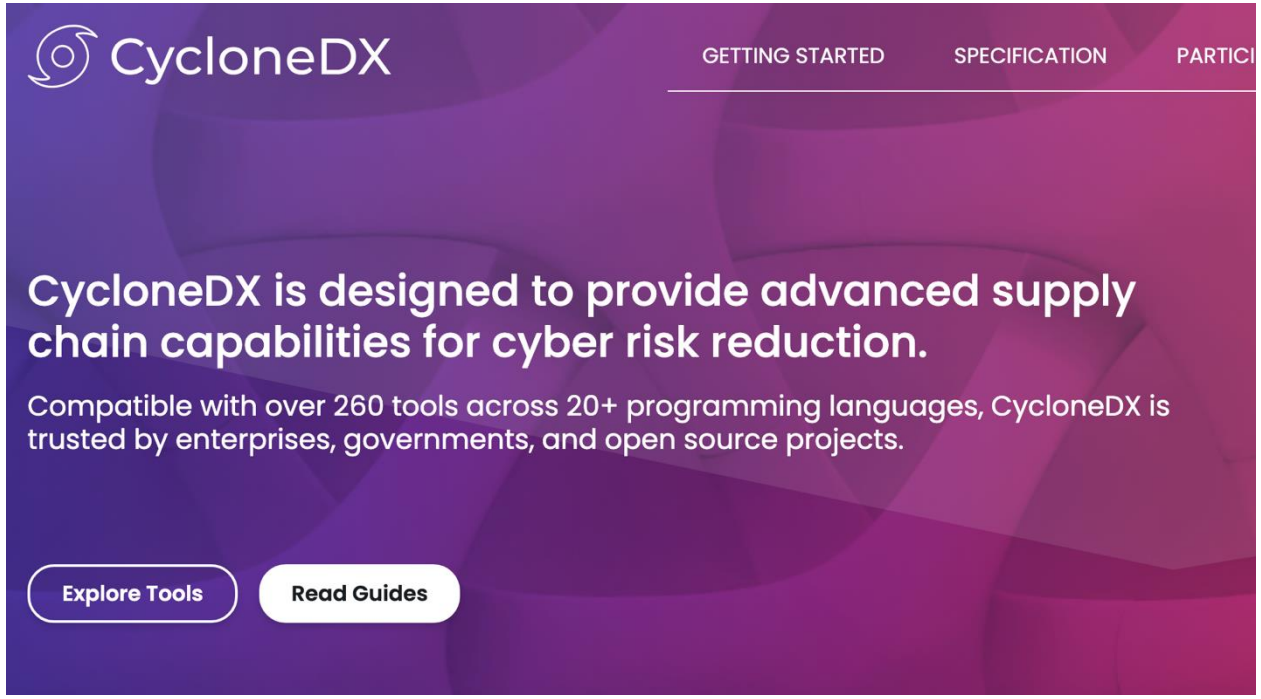
- El análisis de composición de software (SCA) es el proceso de identificar todas las dependencias de un sistema (librerías, paquetes, versiones) y verificar si alguna tiene vulnerabilidades conocidas o problemas de licencia.

syft

grype

Estándares y automatización





https://spdx.dev/

https://cyclonedx.org/

Preguntas clave

- Adopción en proyectos open source
- ¿La generación de SBOMs es siempre válida?
- ¿Diferentes herramientas producen siempre el mismo resultado?
- ¿Las herramientas son capaces de generar SBOMs en todos los casos?

Tarea 1 (4 de Mayo)

- 3 Lecturas
  - Papers 1, 2, y 3 (disponibles en data/papers)
- Instalar devContainer y generar SBOMs de 10 repositories
- https://github.com/trending
- https://github.com/dci-courses/produccion_software_emi305

Evaluación del módulo

- Tarea 1: generación de sboms, 30%
- Tarea 2: extracción de vulnerabilidades, 30%
- Tarea 3: análisis de resultados, 40%